

数字化时代智慧供应链的信息安全风险浅析

工程领域前沿讲座课程感受

崔 崑

(清华大学自动化系, 北京 100084)

摘要

数字化时代, 智慧供应链进入了发展期。基于物联网的智慧供应链, 面对了大量的针对物联网的安全威胁和挑战。文章分析了三种典型的针对物联网的攻击类型以及其背后的安全缺失; 并从规划建设、运维管理、生产采购等方面提出了应对策略, 最后对安全的智慧供应链发展提出了展望。

关键词: 数字化; 智慧供应链; 物联网; 可信计算; 零信任

0. 引言

笔者近日聆听了刘大成教授关于《数字化时代全球产业链及供应链变革》的讲座, 深切体会到了数字化为全球经济及供应链带来的发展。笔者结合日常工作及研究, 写成此文。

1. 背景

1.1. 数字化带来供应链高速发展

自第二次工业革命以来, 科技发展经历了信息化、网络化、数字化的三个发展阶段。信息化使得人与设备之间具备了数据互联的能力, 管理者可以通过 ERP、MES 等系统对企业的资源进行计划、调度和监控。网络化解决了人与人之间的数据联通的问题, 在保证规模化生产的前提下, 接用户个性化的需求和服务商差异化的供给的对接成为可能。数字化则提供了设备与设备的数据互联的能力, 赛博物理系统(Cyber-Physics System, CPS)通过数字的自组织形成自洽[1]。

智慧供应链在信息化、网络化、数字化的发展过程中也经历了孕育期、萌芽期和发展期三个阶段。

“百年老店”香港利丰集团建立了与众多供应商的所有者和管理层的密切的联系。因此，它对各个供应商的生产能力和业务习惯有了全面掌握。据了解，利丰集团在全球 40 多个国家和地区拥有 15000 多家合规供应商，它们是生产商、运输商甚至是设计公司 and 市场营销公司。一旦利丰集团接到订单，利丰会根据客户的需求，在 15000 多家供应商中选择合适的合作者来构成供应链，帮助客户完成目标。利丰集团把从供应商网络中所带来的利益传递给客户，并且重视与供应商之间建立信誉；因此，供应商通常会优先处理利丰的订单。凭借信息化的红利，利丰集团在 2000 年就实现了 32 亿美元收入；2001 年实现了 203 亿美元收入，当年市值为 2050 亿港元[1]。

随着网络化的到来，人与人之间的信息、数据开始连通。供应商和客户利用互联网实现了近零成本、近零延迟的精准对接并形成规模化。利丰集团在信息化时代建立的居间优势瞬间瓦解。

在数字化技术的推动下，供应链在提升效率和降低成本方面都有了更加快速的提升。数字技术在企业内部，实现了供应链各个环节间的无缝连接，提高了供应链各环节的可视和协调，有效控制风险，提升了整个供应链的透明度。在企业外部，数字技术可以将相应信息和突发问题实时反馈给客户或上游供应商，做到及时与客户沟通，快速解决客户问题，提高客户满意度。在数字化的助益下，供应链可以使用更少的资源完成更多的目标，具备了“智慧”的能力。而结合大数据、认知技术及人工智能等新兴科技，企业更具备了“预测”的能力，企业的管理者能够更早的做出决策，从而产生更大的收益。这些新兴科技将助力供应链从“智慧”发展到“智能”。

1.2. 物联网对智慧供应链的必要性

数字化是智慧供应链发展的关键要素。而数字化的基础之一则是物联网(Internet of Things, IoT)技术。

“物联网”的概念于 1999 年由麻省理工学院的 Auto-ID 实验室提出。2005 年 11 月 17 日，在突尼斯举行的信息社会世界峰会（WSIS）上，国际电信联盟（ITU）发布了《ITU 互联网报告 2005：物联网》，正式提出了“物联网”的概念。报告指出，无所不在的

“物联网”通信时代即将来临。自 2009 年 8 月温家宝总理提出“感知中国”以来,物联网被正式列为国家五大新兴战略性产业之一, 写入“政府工作报告”, 物联网在中国受到了全社会极大的关注。伴随着高速网络 and 智能设备的发展, 物联网已经深入人们生产、生活等众多领域, 开启了万物互联的时代。

物联网使得设备与设备之间具备了进行数据交换的能力, 是数字化技术的重要依托; 同时物联网的终端具备了对生产设备、环境、资源等信息低成本、低能耗、实时性的监控的能力, 是智慧供应链上风险防范的重要技术依托之一。

1.3. 物联网安全事件与日俱增

物联网的高速发展的同时也展示出更多的脆弱性和更大的受攻击面。非营利组织云安全联盟(Cloud Security Alliance, CSA) 发布的白皮书《Security Guidance for Early Adopters of the Internet of Things (IoT)》中提到物联网带来如下新的挑战:

- (1) 增加的隐私问题经常让人感到困惑;
- (2) 平台安全的局限性使得基本的安全控制面临挑战;
- (3) 普遍存在的移动性使得追踪和资产管理面临挑战;
- (4) 设备的数量巨大使得常规的更新和维护操作面临挑战;
- (5) 基于云的操作使得边界安全不太有效。

2015 年的乌克兰停电事件被认为是首次由网络攻击导致的电力中断事件, 攻击者利用漏洞, 通过 SCADA 系统直接下达断电控制指令, 并结合电话拒绝服务攻击, 有意的延缓运维进度, 造成乌克兰国内大面积停电[2]。

2016 年 9 月 Mirai 物联网僵尸网络对 Krebs on Security 网站发动了 DDoS 攻击, 攻击流量达到了 620 Gbps[3]。同年 10 月, Dyn 公司提供的 DNS 服务遭到了数次通过 Mirai 发起的大型 DDoS 攻击, 牵涉到的受感染物联网设备数量众多。这次攻击使得数个高访问量的网站无法正常打开, 其中包括 GitHub、Twitter、Reddit、Netflix 和 Airbnb 等[3]; 这次攻击几乎使得“半个美国掉线”。

2. 物联网信息安全隐患及风险

2.1. 攻击者目的及影响

攻击者对物联网系统的攻击目的相对传统的网络攻击更加聚焦。通常可以分为以破坏为目的的攻击、以数据窃取为目的的攻击和以欺诈获利为目的的攻击。

2.1.1. 以破坏为目的的攻击及其影响

计算机病毒是最常见的以破坏为目的的攻击形式，通常病毒攻击仅对单体攻击，并造成设备损坏最终导致数据丢失等后果。随着网络时代的到来，病毒开始通过网络传播，会造成大面积的感染，但仍然是以对单体设备的攻击和破坏为首要目的。由于反病毒手段的不断升级，病毒直接感染核心设备及服务的可能性越来越低。而僵尸网络(Botnet)的出现，为攻击核心设备及服务提供了新的可能。僵尸网络是指采用一种或多种传播手段，将大量主机感染僵尸(bot)程序病毒，从而在控制者和被感染主机之间所形成的一个可一对多控制的网络[2]。攻击者通过各种途径传播僵尸程序感染互联网上的大量主机，而被感染的主机将通过一个控制信道接收攻击者的指令，组成一个僵尸网络。由于物联网终端设备的计算能力受限，防御手段缺失，成为僵尸程序病毒的良好载体。对单一物联终端的攻击对物联网的整体破坏影响不大，甚至可以说微乎其微；但是以 Mirai 为代表的僵尸网络则会充分利用物联网的终端易攻击、数量大的特性，控制大量的终端设备，对核心目标进行 DDoS 攻击，造成国民经济的严重损害，严重时甚至会威胁到国家安全。研究表明，Mirai 从 2016 年 8 月首次被侦测，到 2016 年 11 月底便已经感染了超过 60 万台设备[3]。

2.1.2. 以数据窃取为目的的攻击及其影响

针对 IoT 的以数据窃取为目的的攻击也分为两种。一种是通过物联终端自身的传感设备获取终端附近的环境信息，包括视频、声音、温度、湿度等。这类攻击通常不会对核心数据造成影响，但仍然会导致包括个人隐私，商业乃至国家秘密等信息泄露。另一类以数据窃取为目的的攻击是通过物联终端作为跳板，利用物联终端与云端服务器的通信链路以及云端服务器的漏洞进行攻击并窃取数据。这类攻击往往能获得大量的包括公民信息在内的隐私或商业机密数据，甚至是关系到国家安全的海量数据；造成重大的经济损失和社会影响。

2.1.3. 以欺诈获利为目的的攻击及其影响

以欺诈获利为目的的攻击在物联网环境中也很常见。攻击者往往通过物联终端设备的缺陷进入物联网中，并进一步寻找核心数据服务器进行攻击并实施包括数据篡改、删除、

加密勒索等行为。这类攻击的核心目的是获利，在获得满意的回报后，黑客通常不会对核心系统或数据造成破坏，但仍然会造成经济损失或较为恶劣的社会影响。2019 年，国内曾经出现一起黑客通过入侵公安视频专网，进入车辆违规系统，并进行有偿“销分”的案件。

2.2. 隐患分析

无论黑客进行攻击的目的如何，其攻击途径往往是利用物联网系统的技术缺陷或管理缺失。下面对常见的攻击途径进行浅析。

2.2.1. 云端服务及应用缺陷

由于云端服务所部署的数据中心通常都是“重兵把守”，即使出现缺陷，被直接攻击的可能性也相对较小，而且往往都能够得以迅速修补。攻击者通常会寻找 SQL 注入，跨站脚本等漏洞进行攻击，这类攻击行为往往容易被防火墙、WAF(Web Application Firewall)等边界安全设备发现。但是有一类缺陷是由于服务设计中的逻辑错误导致的，利用这类缺陷的攻击者行为和正常用户无异，往往难于发现，但一旦被黑客掌握，却会带来重大的影响。笔者就曾经向 CNVD 报告了某智慧门禁系统在网络失效后的应急开门功能的逻辑漏洞(CNVD-2019-19059)。对于智慧供应链这种业务流程较长，数据交互节点众多的服务，特别要注意这种逻辑错误。

2.2.2. 网络缺陷

网络缺陷包括物联网系统建设中对于边界的防护缺失或者对于网络设备接入的管控缺失，以及所使用的网络协议的缺陷。由于物联网通常设备数量多，分布广，边界防护很难做到尽善尽美，设备接入管控也会受到物联终端功能简单计算力低的影响而不能完全起作用，经常需要物理手段协同防护。而攻击者往往会选择分布较为偏僻的物联终端，绕过物理防护进行渗透。除了有线连接之外，大量的物联终端设备使用无线通信协议，包括 4G、5G、NB-IoT、Wi-Fi、蓝牙、Zigbee、LoRa、红外等都是目前较为常见的终端无线通信协议。2016 年研究者发现利用 ZigBee 协议中的漏洞能够感染并传播智能灯泡“蠕虫”。仅仅通过感染一个智能灯泡，可以在短短“几分钟内迅速造成一个城市的大面积灾难性破坏”[5]。智慧供应链依赖大量的传感器，接入方式和涉及的协议也各不相同，对智慧供应链的安全带来了重大挑战。

2.2.3. 设备缺陷

由于物联网终端结构简单、成本低，而且普遍都有低能耗、小体积等要求，物联网终端的计算能力受到较大的限制。为了满足设备功能，厂商通常会对系统进行简化，漏洞的存在难以避免，而系统的更新也容易被忽视。相比于具有相对成熟的安全防护的计算机、手机系统而言，物联网终端的安全防护手段同样有很大缺失。此外，随着针对物联网终端的攻击活动的增多，通过对物联网终端设备固件实施逆向后进行漏洞分析的技术已经较为普遍，已经成为攻击者发现物联网终端漏洞的一个最常用手段。而一个固件漏洞可以影响着成千上万甚至上百万的设备：从简单的默认用户名、密码到静态代码后门、明文传输等，过分简单的登录入口，或者不加密的通讯传输，都让攻击者能够更加轻松地“拥有”目标设备。通过对 GeekPwn 比赛中的项目脆弱性存在于“云、管、端”不同地方的占比进行统计，物联网终端存在安全威胁的设备以 83% 的超高比例，位居第一。相比之下，物联网中存在的云端逻辑问题只占 12%，通讯链路威胁最少，占比仅为 6%[5]。智慧供应链中引入了大量的移动终端设备，对终端的保护很难如传统计算机一样集中管理；攻击者更加容易对终端设备进行分析并获取设备缺陷。

2.2.4. 人为因素

除了上述由于技术造成的缺陷之外，人的因素也日渐成为物联网重大的安全隐患。利用社会工程学的非传统网络攻击始终存在。2014 年，安全公司 Trustwave 下的 SpiderLabs 安全小组在对多家钢铁、石油公司安全管理系统进行测试时，通过伪造可信任发件人名单，向公司普通员工发送信息调查表和木马测试程序，并声称其电脑存在安全风险需要进行反病毒升级，若同时填写调查表则可以获得现金奖励。很多员工出于小利益诱惑，未经仔细核验便填写了信息表并执行了程序[6]。当前社会工程学理念已经充分融入到多种网络攻击形式中，对其防范也愈加困难。出于部署简单、管理容易等需求的考量，大量的物联网设备存在者弱口令，甚至“千机一密”的问题。此外，由于物联网终端设备和业务数据直接相关，为了避免设备失效造成业务损失，很多终端设备存在着“终生”不升级的现象，导致新暴露的安全问题无法得到修复。因此，非盈利组织 Open Web Application Security Project® (OWASP) 将“缺乏设备管理”列入构建、部署或管理物联网系统时应该规避的十大问题之一。

3. 安全对策及建议

3.1. 体系建设

目前绝大多数物联网系统的安全体系设计和建设是在物联网系统进入正常生产状态后才开始的。因此，在设计相关安全体系的时候，不得不迁就包括业务连续性等各种实际需求；同时由于生产系统设计时，往往并未考虑到安全需求，可扩展性不足，安全无法与业务高度耦合，反而影响业务效率。最终导致的结果就是多数安全措施被放弃，在暴露出众多安全隐患的同时也造成了巨大的浪费。

安全体系应当与数字化业务体系同步规划，同步设计，同步实施。在安全体系设计的同时，充分考虑业务需求；将安全管控，融入业务流程。同时在业务体系设计的时候，也应当充分考虑安全要素，选择贴合业务的安全体系，规范数字化设备的安全标准，提升安全管理水平。

在实际应用中，以下安全体系能够应对物联网系统“云-管-端”的架构以及泛在互联的特点。

3.1.1. 可信计算

可信计算技术通过“计算+保护”的双体系结构，有效弥补了计算平台本体的安全漏洞，可保障物联网系统内部操作系统、业务程序、操作逻辑的完整性，使其免受恶意代码和操作的干扰，达到类似生物体的安全免疫系统功效。其主要特性包括：公钥、对称双密码主动系统免疫，终端、服务器、存储系统体系可信，宿主+可信双节点平行架构，以及基于网络可信服务验证和动态度量实时感知[7]。

可信计算一般分为节点可信、网络连接可信和应用可信 3 个层次：节点可信层为整个主动免疫系统提供信任起点，是主动免疫系统的源头；网络连接可信层承担节点之间交互的免疫，是网络可信的关键部分；应用可信层为节点和网络提供免疫支持和服务，更新安全策略，增强节点的免疫能力[8]。可信计算同时要求必须对人的操作访问策略四要素（主体、客体、操作、环境）进行动态可信度量、识别和控制。

3.1.2. 零信任架构

在《零信任网络》一书中，埃文.吉尔曼（Evan Gilman）和道格.巴斯(Doug Barth)将零信任的定义建立在如下五个基本假定之上：网络始终处于危险的环境中，网络中始终存在外部或内部威胁，网络的位置无法确定网络的可信程度，所有的设备、用户和网络流量都应当经过认证和授权，以及安全策略必须是基于尽可能多的数据源动态计算得出[9]。零信任的核心思想是，所有人、事、物皆不可信以及在访问及授权前先行验证[10]。

零信任架构的本质是以身份为基础的动态可信访问控制，聚焦身份、信任、业务访问和动态访问控制等维度的安全能力，基于业务场景的人、流程、环境、访问上下文等多维的因素，对信任进行持续评估，并通过信任等级对权限进行动态调整，形成具备较强风险应对能力的动态自适应的安全闭环体系。

自零信任于 2010 年被提出以来，已经得到越来越的认可。2014 年谷歌公司(Google)通过 BeyondCorp 项目在内部实施了零信任架构，并成功的舍弃了对传统 VPN 的使用[11]。使得来自任何地方的员工都能安全地访问企业业务。在物联网中，由于大量的终端设备不具备对建立 VPN 网络的支持，是应用零信任架构的最佳场景。

3.1.3. 纵深防御

纵深防御(Defence-in-Depth, DiD) 要求将安全性应用于多个层，其工作原理是为每个层提供不同类型的保护，以便成为阻止攻击的最佳手段。这些层也可以防止不同的问题，全方位覆盖多个不同问题。

对于已经投入生产，并且具备一定安全防护措施的物联网体系，无论进行可信计算还是零信任改造都会带来较大的影响。通过纵深防御的思路，有可能在安全性和可用性上寻求一个平衡点，是在客观条件受限的情况下的选择。

从思想来说，可信计算和零信任的核心理念之一都是对所有的访问进行验证并且动态授权；因此，在特定场景下，二者也可以依据纵深防御的理念分层布局，强化安全保护。

3.2. 管理运维

可以看到，无论基于何种安全体系建设，有效识别和管理网络中的资源（设备、人、非人账号、服务等），以及他们的安全状态，都是维护网络安全的基础。在物联网体系中，由于海量异构设备的存在，很难通过单一手段和技术进行资源的发现与识别。通过多数据源和大数据分析的技术，物联网的管理者可以更加有效地识别、管理和维护网络中的

资源。同时，加强人的管理和体制建设也是必要的手段。安全是管理者意志的延伸，技术是管理理念的延伸。最新的《信息安全技术网络安全等级保护基本要求》（等保 2.0）强调的安全管理的重要性，并提出安全管理制度、安全管理机构、安全管理人员、安全建设管理和安全运维管理五部分具体的要求[12]。

3.3. 研发与采购，安全前置

大部分安全问题来自于物联网设备在设计和开发过程中。出于成本考虑多数开发者只考虑功能特性而忽视安全因素。而物联网设备的使用者也只关注产品的性能而忽视安全性。在这样的情况下，一旦暴露安全问题，影响非常严重。为此，云安全联盟（CSA）在 2016 年开发并发布了“物联网安全指南”（Feature-proofing the Connected world: 13 steps to Developing Secure IoT Products），提出了在物联网产品开发时应遵循的 13 个方面，包括安全开发方法、安全开发和整合环境、识别框架平台的安全属性、隐私保护等[13]。而设备的使用者则应构建从设备供应需求环节就切入的安全保障，同步验证功能性需求与安全性需求，为企业数字化发展提供“源头”保护。

3.4. 安全持续监控与威胁情报

在可信计算和零信任架构中，都提出了访问请求动态度量，对访问控制策略动态调整的要求。这需要物联网的拥有者和管理者在实际部署应用后，对整个网络的安全态势持续监控，并具备依据安全态势不断更新和调整访问控制策略的能力。安全持续监控要求物联网中具备能够持续收集并分析各类信息日志的能力，通常与安全信息与事件管理系统（Security Information and Event Management system, SIEM）配合。

同时，外界的威胁情报也是调整访问控制策略的重要依据之一。威胁情报为访问控制策略调整提供了包括最新的攻击情报、系统漏洞、恶意软件等信息。访问控制引擎可以据此调整整个网络环境中的资源的可信度。

3.5. 区块链的应用

将区块链与供应链融合，解决了供应链上下游的信任问题，并通过“去中心化”摆脱了高成本、低效率的“中介”。区块链的数据不可篡改、不可抵赖性，为供应链金融提供了风险防控的可能。但区块链的引入也将带来新的安全风险，自 2011 年到 2019 年，全球范围内由区块链的重大安全事件导致的损失已经超过 30 亿美元，超过 90% 的安全事件集

中在智能合约和业务应用。做好智能合约和业务应用的安全审计和威胁情报服务将是大规模应用区块链技术的基础。

4. 结束语

牛津大学的马丁·克里斯多夫教授指出：“21 世纪的竞争不是企业与企业之间的竞争，而是供应链与供应链的竞争” [1]。数字化时代的智慧供应链，是经济发展的重要推动力之一。2017 年 10 月 5 日，我国政府发布了积极推进供应链创新与应用的国家战略。此次 COVID-19 重大疫情后，全球经济与产业结构必将发生巨大的变革。构建全新的智慧物流供应链体系，对促进经济“双循环”的新发展格局有重要意义。在发展智慧供应链体系的同时，必须同步考虑到的数字化时代新的技术所带来的新的安全风险。未雨绸缪，让信息安全技术为智慧供应链的发展保驾护航。

参考文献：

- [1] 刘大成.重大疫情中后期面向数字化的智慧物流供应链体系构建[J].供应链管理,2020,1(06):5-21.
- [2] 杨至元, 张仕鹏, 孙浩. 电力系统信息物理网络安全综合分析与风险研究[J]. 南方能源建设, 2020(3).
- [3] Manos Antonakakis, Tim April, Michael Bailey, Matthew Bernhard, Elie Bursztein, Jaime Cochran, Zakir Durumeric, J. Alex Halderman, Luca Invernizzi, Michalis Kallitsis, Deepak Kumar, Chaz Lever, Zane Ma, Joshua Mason, Damian Menscher, Chad Seaman, Nick Sullivan, Kurt Thomas, and Yi Zhou. 2017. Understanding the mirai botnet. In Proceedings of the 26th USENIX Conference on Security Symposium (SEC'17). USENIX Association, USA, 1093–1110.
- [4] 金双民,郑辉,段海新. 僵尸网络研究系列文章之一 僵尸网络研究概述[J]. 中国教育网络,2006,06:51-54.
- [5] 上海社会科学院互联网研究中心. 智能物联网安全风险报告[J]. 信息安全与通信保密 2017-07
- [6] 张猛. 工业物联网安全风险分析及对策研究[J]. 中国工业评论, 2017(4).
- [7] 沈昌祥. 网络强国系列 用可信计算 3.0 筑牢网络安全防线[J]. 信息安全研究, 2017(04):4-12.
- [8] 孙跃,杨晟,龚钢军,杨佳轩,周波.基于可信计算和区块链的配电物联网内生安全研究[J].华电技术,2020,42(08):61-67.
- [9] 【美】埃文·吉尔曼(Evan Gilman),【美】道格·巴斯(Doug Barth). 零信任网络：在不可信网络中构建安全系统[M]. ISBN: 9787115510020
- [10] Zero Trust Architecture[S]. NIST Special Publication 800-207. <https://doi.org/10.6028/NIST.SP.800-207>
- [11] WARD R, BEYER B. BeyondCorp: a new approach to enterprise security[J]. Login, 2014, 39(6): 6-11.

[12] GB/T 22239-2019, 信息安全技术 网络安全等级保护基本要求[S].

[13] I. W. Group, "Future-Proofing the Connected World: 13 Steps to Developing Secure IoT Products," Cloud Security Alliance, 2016.